

DESIGN_DECISION

BOB-174 — Design decision: how a CORRUPT hook store behaves, and why

Revision: 2 **Last modified:** 2026-08-25T18:36:33Z **Item:** BOB-174 (Bug, High) — a corrupt hooks file reads as zero hooks, and the next create destroys the rest **Scope of this document:** the decisions the item required to be *recorded rather than inferred*, and the reasoning and measurements behind each.

0. The root, stated once

`_load_hooks` had one return value — `[]` — for two states with opposite meanings:

State	What it means	Correct answer
hooks.json MISSING	No hooks configured. The fresh-install state.	<code>[]</code> — genuinely empty
hooks.json EXISTS but unreadable	The configured hooks are UNKNOWN to the server. They may still be firing.	<i>not</i> <code>[]</code> — the server cannot answer

Collapsing them is the whole defect. Everything below follows from separating them.

This is a §11.4.201(6) **FALSE-NULL**: a blind instrument and a clean artifact returned the identical quiet zero. The fix is not “handle the exception better” — it is to make the two states **distinguishable at the**

API surface, which is why a new exception type (HookStoreCorruptError) was introduced rather than a sentinel value or a None return.

1. DECISION — GET returns 500, not 200 with a degraded marker

Chosen: GET /api/v1/hooks answers a corrupt store with **HTTP 500** and a detail naming the file and the consequence. The error body carries **no hooks key at all**.

Rejected: 200 {"hooks": [], "count": 0, "degraded": "..."}.

The measurement that decided it

The item flagged that this endpoint is consumed by the frontend, so a bare 200→5xx flip has UI consequences. It was checked rather than assumed.

frontend/src/app/components/dashboard/dashboard.component.ts:794:

```
loadHooks(): void {
  this.api.getHooks().subscribe(h => {
    this.hooks.set(h.hooks || []);
  });
}
```

subscribe() is called with a **next callback only** — no error callback. getHooks() pipes only timeout(...); there is no catchError, no HTTP interceptor and no custom ErrorHandler anywhere in the non-spec frontend sources (verified by grep over frontend/src/app, 2026-08-23). The template renders <tr *ngIf="hooks().length === 0">No hooks registered</tr>.

So, with the frontend **as it stands today**:

Option	What the hooks signal does	What the operator sees	Any signal at all?
500 (chosen)	never updated — stream errors	“No hooks registered”	yes — RxJS rethrows to Angular’s default ErrorHandler →

Option	What the hooks signal does	What the operator sees	Any signal at all?
			console.error, plus a red row in the Network tab
200 + marker	h.hooks \ \ [] → []	“No hooks registered”	no — a clean 200, nothing anywhere

Both render the same wrong sentence today. That is the honest finding, and it is why the argument had to be decided on something other than the current UI. Three things decided it:

1. **A marker only helps consumers that opt in to reading it.** Every consumer that exists today — the dashboard, curl, any operator script — checks the status or nothing. A new field they do not read is silence, which is the §11.4.201(6) shape the item exists to remove. A 500 is understood by every HTTP consumer that already exists, with no coordinated change.
2. **count: 0 on a 200 is a false statement on the wire.** It is not merely uninformative; it is the original lie, re-emitted with a footnote. An error response with no hooks key cannot be misread by a consumer that ignores the status, because there is nothing there to misread — which is why the guard asserts "hooks" not in body.
3. **The 500 leaves a trace even untouched.** A console error and a red network row are not a good UI, but they are a *distinguishable* state, and they are what turns “the hooks tab looks empty” from a dead end into a five-second diagnosis.

Status code: 500, not 503

503 means “temporarily unavailable, retry may help”. A corrupt file does not repair itself and a retry will fail identically; 503 would invite exactly the wrong response. 500 also matches what BOB-173 already established for the write-failure path in this same module, so the two persistence faults present consistently.

HONEST BOUNDARY — what this decision does not fix

The dashboard still shows “No hooks registered” on a corrupt store. This change makes the *API* honest; it does not make the *UI* honest. Making the UI render a distinct degraded state requires an

error callback in `loadHooks()` and a template branch — both in `frontend/`, which is outside this item's file scope and live under a sibling stream. That is a **known, unfixed gap**, recorded here so it is a tracked decision rather than an oversight, and it is the natural follow-up item. The API contract chosen above is deliberately the one that makes such a frontend fix a pure addition (read the status) rather than a renegotiation (agree on a new field).

2. DECISION — create and delete refuse; they never clobber

POST and DELETE both answer a corrupt store with **500** and change nothing on disk.

This is §11.4.252 applied literally: the path combines **mutation of a shared resource** (rewriting the store) with an **external side effect** (a hook is an outbound call the system will or will not later make), so when an input to its correctness is unverifiable it **fails closed**.

The alternative — “read what we can, write what we have” — is precisely the defect. Pre-fix, create received `[]` from a misread of a three-hook file, appended one hook, and wrote a one-element list over the top. Measured on the fixed-but-for-this tree:

```
'prod-hook-0' is no longer in the hook store.  
assert 'prod-hook-0' in ' [{"hook_id": "f71c5ebb-...", "name":  
"bob174-new-hook", ...}] '
```

Note what is destroyed. A truncated file still contains the operator's hook definitions in plain text — it is **hand-repairable**. After the clobber it is not. The create turned a recoverable state into an unrecoverable one, and reported 200.

`test_recoverable_operator_data_is_still_recoverable` is the guard that pins exactly that property.

DELETE gets the same treatment for a second reason: its 404 is a *claim about the file's contents* (“Hook not found”). Making that claim about a file that was never successfully read is a false report, not a null result — pre-fix, deleting a hook that **was** in the store answered 404.

3. DECISION — `dispatch_event` logs and dispatches nothing; it does not raise

This is the one place a log-only arm was accepted, and it is the decision most in tension with the rest of the item, so the reasoning is recorded in full.

`dispatch_event` is awaited **inline** by the search and download handlers. Raising `HookStoreCorruptError` out of it would turn an unreadable hooks file into a **500 on SEARCH and on DOWNLOAD** — a §11.4.201(1) false-positive refusal that breaks the product’s primary capabilities over an unrelated subsystem’s state. That is strictly worse than the gap it would close.

CORRECTION (Revision 2, §11.4.201(9)). Revision 1 said “14 call sites”. That number does not reproduce and has been withdrawn. Re-measured 2026-08-25 by an **AST walk** of `api/routes.py` rather than by `grep`, because `grep` answers a different question here:

Measurement	Value
<code>await dispatch_event(...)</code> call sites (AST)	8 — lines 488, 507, 598, 760, 1190, 1309, 1373, 1419
Total textual occurrences of <code>dispatch_event</code>	13 — the 8 above plus 5 from <code>.hooks import dispatch_event</code> lines
Revision 1’s claim	14 — matches neither

The substance is unchanged, and it was established by RUNNING the code, not by counting. The independent review removed the corrupt-store arm and drove a real corrupt store through the real app: `/api/v1/search` (`routes.py:488`) and `/api/v1/download` (`routes.py:1190`) both returned **HTTP 500**. That is the measurement the decision rests on.

The AST walk explains *why* it propagates: of the 8 call sites, **7 have no LEXICALLY enclosing `try/except`** — only line 507, inside `_background()`, sits in one (`try` at line 501). “Lexically” is the honest qualifier, because an ancestor walk sees only the syntactic nesting in this file; it cannot rule out a handler further up a dynamic call chain. It does not need to: the end-to-end run above already settled the

question, and the static reading merely accounts for the result rather than substituting for it (§11.4.226 — runtime evidence for a runtime claim).

So a wrong call count changed nothing about the conclusion — which is precisely why it is corrected here rather than quietly dropped (§11.4.194(2)): an unproven figure that happens not to be load-bearing is still an unproven figure, and leaving it standing invites the next reader to trust the next one.

So the chosen behaviour is: **dispatch no hooks** (fail closed on the side effect — the set of hooks to run is unknown, so none run), **log an ERROR** naming the file, and **return**.

HONEST BOUNDARY (§11.4.6): a log-only arm is the exact shape this item condemns everywhere else. It is accepted *here and only here* because `dispatch_event` is fire-and-forget and has **no response channel of its own to be honest on**. `GET /api/v1/hooks` is the surface where the operator learns the store is broken, and it now says so loudly. If a future change gives the dispatch path a status surface (a health field, an SSE event, a hook-execution log entry), that surface should carry this state and this arm should stop being log-only.

4. DECISION — “corrupt” includes wrong shape, bounded at list-of-objects

`HookStoreCorruptError` is raised for:

Input	Why
unreadable file (<code>OSError</code>)	exists, contents unobtainable
truncated / malformed JSON (<code>ValueError</code>)	the crash-mid-write case A5 produces
valid JSON that is not a list (<code>{"hooks": [...]}, "x", 42</code>)	parses cleanly; a fix hardening only <code>json.load</code> would still collapse it to <code>[]</code>
a list containing non-objects (<code>["a", "b"]</code>)	every accessor in this module is <code>h["hook_id"] / h.get("event")</code>

And, found by self-review rather than by the reported chain: a **directory** (or `fifo/socket/device`) at the store `path.os.path.isfile` is `False` for those, so the original guard — and any fix that kept `isfile` — reported them as `MISSING`, i.e. “no hooks configured”. That is the same

conflation in a rarer flavour, so the guard is now `os.path.exists`, letting such a path fall through to the open where the existing `OSError` handler covers it. A broken symlink deliberately stays `MISSING` (`exists` follows links) — nothing readable is there, and that reading is correct.

Deliberately NOT validated: individual keys within each hook object. A hook missing `hook_id` would still fail later in `delete_hook`. That was left alone on purpose — per-key validation risks refusing hand-edited-but-workable files and files carrying fields added by a future version, which is a §11.4.201(1) false-positive refusal of a *healthy* store. The line drawn is: **“could the contents be obtained in the shape this module contracts for”** — not “is every hook well-formed”. Stricter validation is a defensible future change, but it is a different decision with a different risk profile and should be made on its own evidence.

`HookStoreCorruptError` is kept **distinct** from BOB-173’s `HookPersistenceError` rather than merged: one means a `READ` failed, the other a `WRITE`. They arrive at different points and an operator repairs them differently. Collapsing them would recreate, one level up, the same “two states, one signal” defect this item exists to remove.

5. DECISION — the atomic write is `theme_state`’s pattern, reused

`_save_hooks` now writes via `tempfile.mkstemp` → `json.dump` → `flush` → `fsync` → `os.replace`, with the temp file unlinked on any failure.

This is **not invented here**. It is the pattern already established in this codebase by `download-proxy/src/api/theme_state.py::_write_atomic` (§11.4.28 — reuse, do not re-derive). The temp file is created **in the destination directory**, not `/tmp`.

CORRECTION (Revision 2). Revision 1 justified that with “a cross-device rename would silently reintroduce the window being closed”. Measured 2026-08-25, the failure mode is worse than “silently non-atomic” — it does not degrade, it **raises**:

```
os.replace('/tmp/.private/milosvasic/.hooks-zwrc_rj1.json',
          '/dev/shm/bob174-xdev-store-nahelgsk/hooks.json')
-> OSError: [Errno 18] Invalid cross-device link
```

So losing the `dir=` kwarg does not weaken durability, it makes **every hook write fail with HTTP 500**. That matters because it is the container's ordinary geometry, not an exotic one — **verified against `docker-compose.yml`, not assumed**. `HOOKS_FILE` is `/config/download-proxy/hooks.json`, and the `download-proxy` service mounts:

```
volumes:
  - ./config:/config                                # line 247
  - ./download-proxy:/config/download-proxy          # line 249 <-
    the store's directory
  - ./tmp:/shared-tmp                               # line 250 <-
    note: /shared-tmp, NOT /tmp
```

So the store's directory is a **host bind-mount**, while `/tmp` has **no mount entry at all** and is therefore the container's own writable overlay layer. Different filesystems — which is exactly the condition under which `os.replace` raises `EXDEV`. A hooks write is cross-device in **every deployed instance** and same-device in **every ordinary test**, because `pytest's tmp_path` lives under `tempfile.gettempdir()`. The suite was therefore *structurally* blind to it, and the reviewer's mutation dropping the kwarg passed the entire suite.

Closed at two layers, because neither alone is sufficient:

Guard	What it asserts	Where it runs
TestAtomicWriteMechanicsArePinned	the <code>dir=</code> kwarg is passed and equals the store directory, and the file replaced in is the temp file written	every host — device-independent, asserts the call
TestTheCrossDeviceFailureIsCaughtForReal	a real create against a store on a genuinely different	hosts with a second writable filesystem; honest §11.4.3 SKIP-

Guard	What it asserts	Where it runs
	filesystem succeeds	with-reason elsewhere

The second is the outcome oracle — nothing is simulated, no `os.replace` is patched, the kernel raises `EXDEV` or it does not — and it fails on the un-pinned code with the verbatim `errno-18` message above.

It was **not** extracted into a shared helper, which is the obvious right end-state, because that means editing `theme_state.py` — outside this item’s file scope. Recorded as a follow-up.

Why fix the write at all when A1 now catches the corruption it produces? Because A5 is the link that **manufactures** the corrupt file. Guarding only the read leaves every crash mid-write destroying the store and leaves the operator with a repair job; the guard downstream turns silent data loss into a visible 500, which is better but is not the same as not losing the data.

DECISION — the permission-semantics changes this carries, accepted knowingly

An atomic write changes *which permission governs* **and what mode the file ends up with**. Both were measured, not assumed. Revision 1 documented only the first; the second was an enumeration gap in the section whose whole job is to enumerate, and is added here (Revision 2).

(a) WHICH permission governs.

```
append to a 0400 file : REFUSED (Permission denied)
os.replace over 0400  : SUCCEEDS
mkstemp in a 0500 dir : REFUSED (Permission denied)  <- the
atomic write fails here
```

So **a hooks.json chmod’ed 0400 no longer refuses a write**. `os.replace` relinks a directory entry and never consults the target file’s mode; what governs now is write permission on the **directory**.

(b) WHAT MODE the store ends up with — every write now resets it 0644 → 0600. Measured 2026-08-25 on a host with `umask 022`:

```
1. fresh in-place open(w) creates mode : 0644
2. operator/umask state on disk          : 0644
3. after an IN-PLACE rewrite             : 0644  <- the OLD path
```

PRESERVED the mode

4. `mkstemp` creates the temp file at `: 0600` <- `mkstemp` is owner-only by design

5. after the `ATOMIC` replace, target is `: 0600` <- the `TEMP` file's mode is CARRIED

`os.replace` does not copy content into the destination inode, it **relinks the temp file's inode into the destination name** — so the destination inherits the temp file's mode, owner and timestamps, and whatever mode `hooks.json` previously had is gone. `mkstemp` deliberately creates `0600`, so the store goes owner-only on the first write after this change.

Accepted, and arguably desirable. The direction is strictly **more restrictive** — no reader that could open the store loses access except *other users*, and the service runs as the file's owner (§ the `PUID=0/PGID=0` note in `CLAUDE.md`; container uid 0 maps to the host operator under rootless podman). It is a defensible default on its own merits:

`hook.environment` is a free-form `dict[str, Any]` persisted verbatim into this file, so an operator can and will put API tokens and credentials in it, and §11.4.10 wants those owner-only rather than world-readable. A hooks store that silently became **less** restrictive would have been a finding; becoming more restrictive is recorded here so that it is a known consequence rather than a surprise, and so that anything later found to depend on group-readability of `hooks.json` has a documented cause to look at first.

Not claimed: that anything in the deployment currently depends on the store's mode either way. Nothing in this project sets, reads or documents it (point 1 of the list below), which is why this is recorded as an accepted consequence rather than tracked as a defect.

This was surfaced by three of BOB-173's `DELETE` tests going red — that file sealed the *file* and probed with `open(target, "a")`, a needle that matched the old in-place rewrite and no longer matches the code (the inverse of the §11.4.199 false reproduction its own header warns about). It was investigated before anything was touched, and the change is **accepted deliberately**, because:

1. File mode on the application's own state store is not a documented protection mechanism anywhere in this project — nothing sets it, nothing relies on it.
2. `theme_state.py` already behaves exactly this way; the alternative would leave two state stores in the same service with different durability guarantees.
3. The realistic deployment failure — the `EACCES-on-/config` case BOB-135 actually hit — is a **directory** permission problem, and it is

still caught. That is why BOB-173's *create* tests never failed: only the file-sealed delete ones did.

4. The thing traded away (an undocumented `chmod`-based lock) is worth far less than the thing gained (the store can never be truncated by an interrupted write).

BOB-173's seal was reconciled to seal the directory using the needle that matches what the code now does (§11.4.120 — assert the NEW mechanism), and the premise above is pinned by a test rather than left as a docstring claim, so reverting the atomic write cannot silently invalidate the seal choice.

6. What is NOT claimed

- **Not claimed:** that the write currently fails in the operator's deployment, or how often. The chain is reproduced under controlled conditions; its real-world frequency is unmeasured.
 - **Not claimed:** that the dashboard now shows anything useful on a corrupt store. It does not — see §1.
 - **Not claimed:** that a corrupt store is now impossible. The atomic write closes the crash-mid-write vector this code owns; external corruption (a bad hand-edit, filesystem damage, a restore from a truncated backup) remains possible, which is exactly why the read guard exists as well.
 - **Not verified:** behaviour under a real `ENOSPC` or a real `SIGKILL` mid-write. The reproduction injects a partial write followed by `OSError(ENOSPC)`, which models the failure faithfully at the point that matters (the file is truncated at open before serialisation completes) but is not the syscall-level event itself.
-

7. A3 — the event vocabulary: DERIVED, not pinned (decision REVERSED in Revision 2)

`VALID_EVENTS` (`api/hooks.py`) and `HookEventType` (`merge_service/hooks.py`) were two sources of truth for one closed set.

The drift consequence is worth stating because it is silent: `create_hook` validates against `VALID_EVENTS`, while `dispatch_event` resolves `HookEventType(event_type)` first and **returns early** on `ValueError`. An event present in one and not the other therefore registers with **HTTP 200** and then **never fires**, logging a warning nobody reads.

The Revision 1 decision, and why it was wrong

Revision 1 chose *pin by assertion, not unify*, on this stated rationale: “requires editing `merge_service/hooks.py`, which is outside this item’s scope and live under a sibling stream”. The independent review measured that rationale **FALSE on all three counts**, and it is corrected here rather than quietly dropped — an unproven-then-false assumption is a review-layer bluff of PASS-bluff severity (§11.4.194(2)):

Revision 1 claim	Measured
requires editing <code>merge_service/hooks.py</code>	False — that file is untouched by this item; the change is one line in <code>api/hooks.py</code>
that file is live under a sibling stream	False — it is not modified in the working tree
(implied) unifying risks an import cycle	False — <code>merge_service.hooks</code> imports only <code>stdlib</code>

The Revision 2 decision — derive

```
from merge_service.hooks import HookEventType
VALID_EVENTS = [event.value for event in HookEventType]
```

Re-measured before taking it: the derived list is **order-identical** to the literal it replaces, so this is a pure de-duplication with no behaviour change. §11.4.241 — pinning by assertion **DETECTS** drift at rung 4; deriving makes drift **unrepresentable** at rung 2, which is the stronger rung and the one the ladder says to prefer when the toolchain supports it.

Import form matters. The import is **absolute** (`from merge_service.hooks import ...`), matching the convention already in this package (`api/routes.py:23`) because `download-proxy/src` is on `sys.path`. A relative form (`from ..merge_service.hooks import ...`) raises “attempted relative import beyond top-level package” and breaks 176 tests — measured, not theorised.

What the guard now guards

TestEventVocabularyCannotDrift's two assertions were written against two literals and, against the source as it now stands, **cannot fail** — the derivation makes the state they check unrepresentable. They were kept, not deleted, because their target moved: what they catch now is **the derivation itself being reverted to a divergent literal**. Measured rather than argued — replacing the comprehension with a hardcoded list carrying one extra event fails both (see EVIDENCE.md, mutation M4). A guard whose mutation still bites is load-bearing; this one bites at its new target.

Guard

tests/unit/api_layer/test_bob174_corrupt_hook_store.py — **35 tests** (28 at Revision 1; +3 later in that round, +4 in Revision 2: two pinning the atomic write's mechanics and two staging a real cross-filesystem store). Evidence — the observed REDs, the GREEN, and **ten** paired \$1.1 mutations, each re-measured against the current file — is in EVIDENCE.md beside this file.